

PRACTICAL LABORATORY ASSIGNMENT

Full Name	OSAWARU PRAISE
Registration Number	C11/26/CGRCE/17564
Date Submitted	25 th September 2026
Course	GRC 102 Week 3

Task 1 Governance Architecture and Stakeholder Map.

1. Governance Gap Assessment

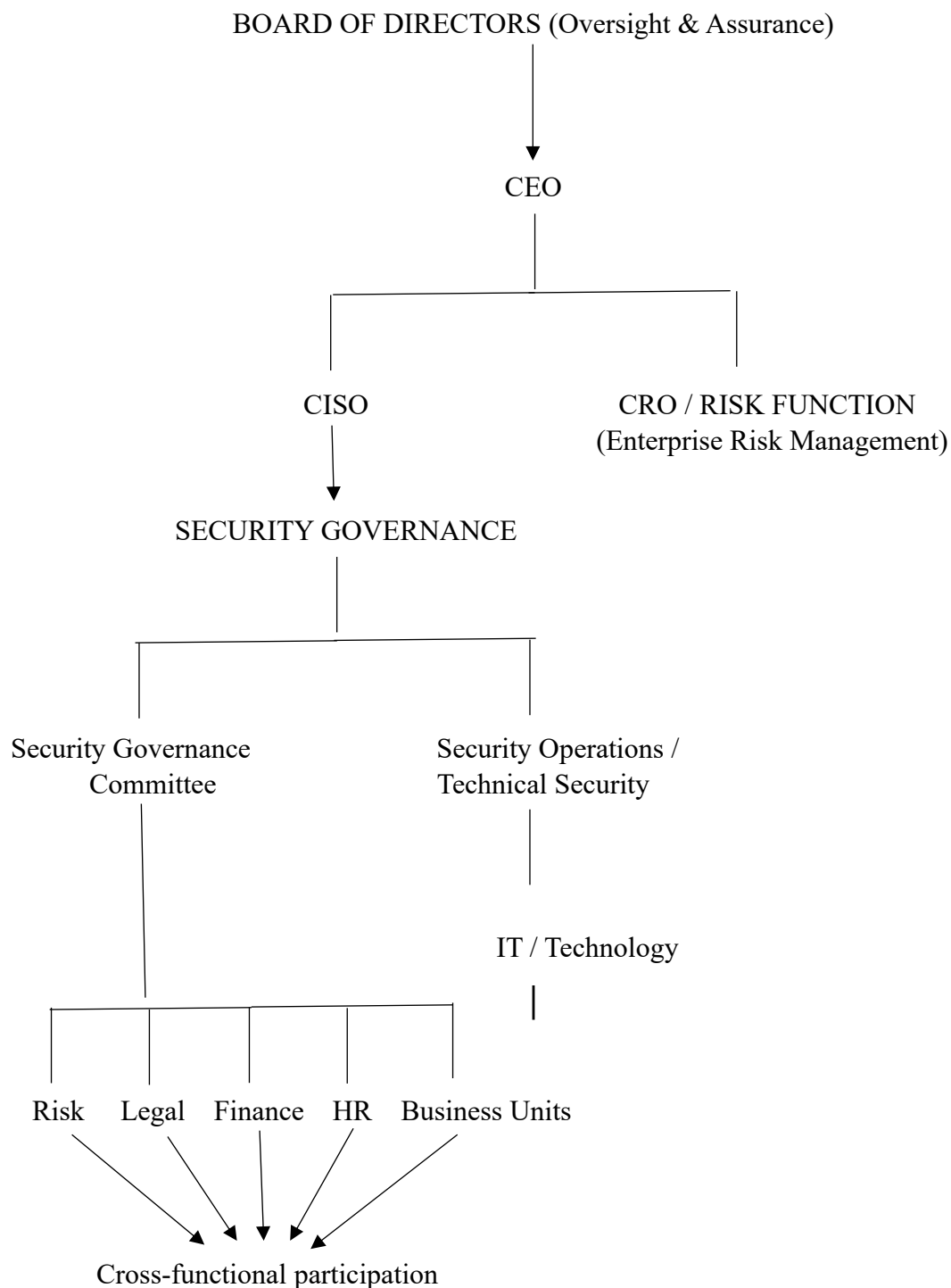
Current weakness	Why it is a problem	Business / risk consequence
Security authority is concentrated in the IT Director	One person is effectively acting as security owner, risk approver and operational decision-maker.	Creates excessive concentration of authority, weak independence and potential conflicts of interest.
No formal security governance committee	There is no structured forum where security, risk, legal, finance, HR and business representatives can collectively make governance decisions.	Security decisions may become IT-centric and business risks may not receive appropriate cross-functional review.
Inconsistent security decisions across business units	Business-unit leaders make local security choices without a consistent governance structure.	Creates inconsistent controls, security gaps and different levels of risk across the organisation.
Limited Board visibility into cyber risk	The Board does not have a reliable mechanism for receiving information about significant cyber risks.	The Board may not have sufficient information to perform effective oversight of risk appetite, material risk and assurance.
Limited CEO visibility into cyber risk	Executive management does not have adequate visibility into the organisation's cyber-risk position.	Security decisions may not be properly aligned with business strategy, growth and acceptable risk.

2. Stakeholder Map

Stakeholder	Authority / Influence	Primary Interest	Information Needed	Governance Contribution
Board of Directors	Very High	Risk appetite, material cyber risk, regulatory exposure, reputation	Material cyber risks, major incidents, risk trends, assurance reports	Provides oversight and challenges management on material cyber risk
CEO	Very High	Business strategy, growth, acceptable risk	Security posture, major risks, financial/business impact	Provides executive accountability and strategic direction

CISO	High	Security strategy, policies, risk and programme effectiveness	Enterprise risk information, security metrics, incidents, compliance status	Leads security governance and coordinates the security programme
CRO / Risk	High	Enterprise risk integration and risk acceptance	Cyber-risk assessments, risk treatment and aggregated risk information	Integrates cyber risk into enterprise risk management
Legal / Compliance	Medium–High	Regulatory and contractual obligations, privacy	Incidents, regulatory requirements, evidence and compliance status	Provides legal/regulatory advice and supports notification decisions
Finance	High	Budget, financial exposure and investment priorities	Security investment requirements, potential losses and risk exposure	Supports financial governance and resource prioritisation
HR	Medium	People governance, awareness and employee controls	Joiner/mover/leaver issues, awareness and conduct matters	Supports people-related security controls and disciplinary processes
IT / Technology	High	Secure technology delivery and operational control	Security requirements, architecture decisions, vulnerabilities and incidents	Implements and operates technical security controls
Business Unit Leaders	Medium–High	Business performance and operational risk	Security requirements, business-unit risks and incidents	Own business processes and implement security requirements

3. Security Governance Organization Chart.



4. Why This Structure Is Appropriate

1. **It removes excessive concentration of authority:** Security governance is no longer concentrated in the IT Director.

2. **It creates cross-functional decision-making:** Security decisions can involve CISO, Risk, Legal, Finance, HR, IT and Business Units, depending on the issue.
3. **It improves executive visibility:** The CEO receives structured information about security risks rather than relying on informal IT reporting.
4. **It improves Board oversight:** Material cyber risks can be escalated to the Board for appropriate oversight.
5. **It supports multiple offices:** A central governance model provides consistency across all five offices while allowing individual business units to manage their operational responsibilities.
6. **It separates governance from operations:** This is probably one of the most important points for the assignment.

Consultant Justification.

Governance → CISO / Executive leadership / Board

Risk → CRO/Risk + relevant business owners

Legal/regulatory → Legal/Compliance

Technology implementation → IT

People controls → HR

Business process risk → Business Units

Task 2 — Governance Responsibility and Authority Matrix

1. Responsibility Profile

Role	Purpose	Key Governance Responsibilities	Decision Authority	Reports / Escalates To	KPIs / Evidence
Board	Provide oversight of enterprise cyber risk and ensure management is accountable	Approve/oversee risk appetite; review material cyber risks; oversee security performance and major incidents	Approves risk appetite and provides oversight of material cyber risk	Receives reports from CEO and relevant governance functions	Board cyber-risk reports; number of material risks reviewed
CEO	Provide executive	Ensure security supports	Executive decisions on	Reports to Board	Security strategy

	accountability and strategic alignment	business objectives; allocate executive attention; oversee management response to significant risks	strategic priorities and significant risk matters within delegated authority		alignment; closure of major management actions
CISO	Lead enterprise security strategy and governance	Develop security strategy; establish policies and standards; coordinate security programme; identify and report security risks; oversee compliance	Security strategy, policies and programme direction within delegated authority	CEO; relevant Board/executive forum; coordinates with CRO/Risk	Security programme performance ; policy compliance
CRO / Risk	Integrate cybersecurity into enterprise risk management	Establish risk methodology; aggregate cyber risks; advise on risk treatment and acceptance	Enterprise risk methodology and risk oversight within delegated authority	CEO / Board risk oversight	Risk assessment completion; percentage of high risks with treatment plans
Legal / Compliance	Provide legal, regulatory and contractual guidance	Interpret regulatory obligations; advise on privacy and contracts; support notification decisions; maintain evidence requirements	Legal/regulatory advice and legal approval within delegated authority	CEO/CISO and relevant governance committee	Regulatory compliance status; timely legal review of material incidents
Finance	Provide financial governance for security investment and exposure	Review security budgets; assess financial exposure; support investment prioritisation	Budget and financial decisions within delegated authority	CEO / executive management	Budget utilisation; security investment tracking

		and financial controls			
HR	Govern people-related security responsibilities	Joiner/mover/leaver controls; security awareness; employee conduct; disciplinary processes	HR decisions concerning personnel processes within delegated authority	CEO / relevant management	Awareness completion; timely access removal for leavers
IT / Technology	Securely implement and operate technology controls	Implement security controls; maintain secure infrastructure; manage vulnerabilities; support continuity and operations	Technical implementation decisions within approved architecture and policy	CISO for security matters; CEO/COO structure for technology operations	Vulnerability remediation; security control implementation

3. Areas of Authority Conflict

Conflict 1 — CISO vs IT

Potential conflict:

The CISO establishes security requirements while IT controls technical implementation.

Example:

The CISO requires stronger endpoint security controls, but IT is responsible for deploying and maintaining them.

Resolution:

CISO owns the security requirement and governance standard; IT owns technical implementation and operation. If implementation is not feasible, IT escalates the issue to the CISO rather than simply overriding the requirement.

Conflict 2 — CISO vs CRO/Risk

Potential conflict:

Both functions are involved in cybersecurity risk.

Resolution:

The CISO provides security risk identification, analysis and security treatment recommendations, while CRO/Risk provides enterprise-risk methodology, aggregation and risk governance.

This distinction prevents cybersecurity risk from becoming isolated from enterprise risk management.

Conflict 3 — CISO vs Legal

Potential conflict:

A security incident may require both security analysis and regulatory/legal judgment.

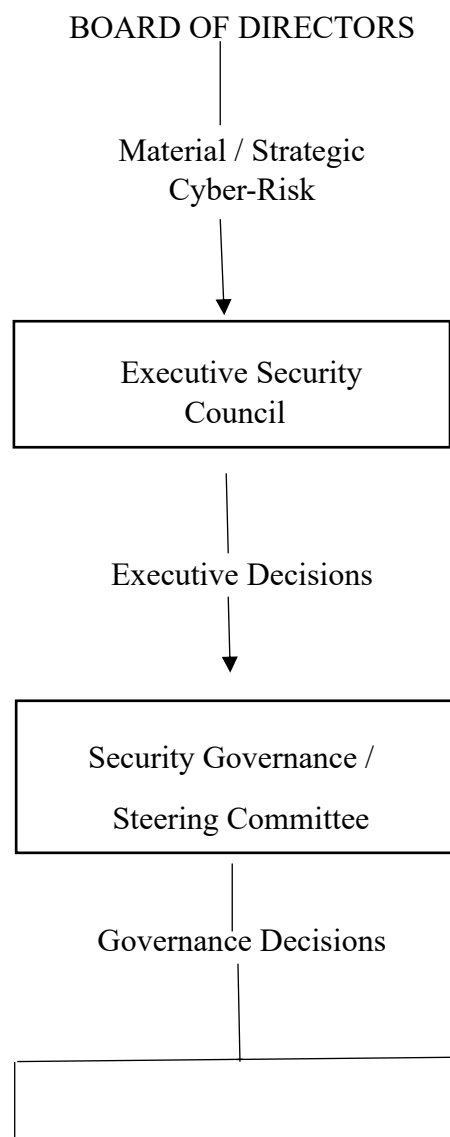
Resolution:

The CISO determines the security facts, impact and technical response, while Legal determines the legal and regulatory implications, including advice concerning notification obligations.

Neither function should independently perform the other's role.

Task 3 — Security Governance Committee Ecosystem.

Proposed Committee Structure





1. Executive Security Council

Purpose

The Executive Security Council provides strategic oversight of cybersecurity and significant cyber risk.

Suggested members

Member	Role
CEO	Chair
CISO	Security governance lead
CRO / Risk	Enterprise risk perspective
CFO / Finance	Financial perspective
General Counsel / Legal	Legal and regulatory perspective
CIO / IT Director	Technology perspective
HR Executive	People-risk perspective
Relevant Business Executive	Business perspective

Main responsibilities

The Council should:

Review significant cybersecurity risks.

Review security strategy and programme performance.

Resolve major cross-functional security issues.

Review significant security investments.

Review major incidents and management responses.

Determine which risks require escalation to the Board.

Ensure cybersecurity remains aligned with business objectives.

2. Security Governance / Steering Committee

This is the main working governance forum.

Unlike the Executive Security Council, it should meet more frequently and deal with ongoing governance matters.

Suggested members

1. CISO — Chair

2. CRO/Risk representative
3. IT representative
4. Legal/Compliance representative
5. Finance representative
6. HR representative
7. Business Unit representatives
8. Security operations representative, where required

Responsibilities

The committee should:

1. Review security risks and treatment plans.
2. Review policy and standards.
3. Monitor security programme progress.
4. Review vulnerability remediation trends.
5. Review third-party security risks.
6. Review security awareness.
7. Coordinate business-unit security requirements.
8. Prepare significant issues for Executive Security Council.
9. Maintain a formal decision log.

3. Specialised Working Group

For TechGlobal, the following is recommended:

Cyber Incident & Response Working Group

Members

1. Security Operations
2. CISO/security representative
3. IT
4. Legal
5. Risk
6. Communications/Corporate Affairs
7. Relevant Business Unit

Purpose: This group focuses on incident preparedness and response rather than general governance.

Responsibilities

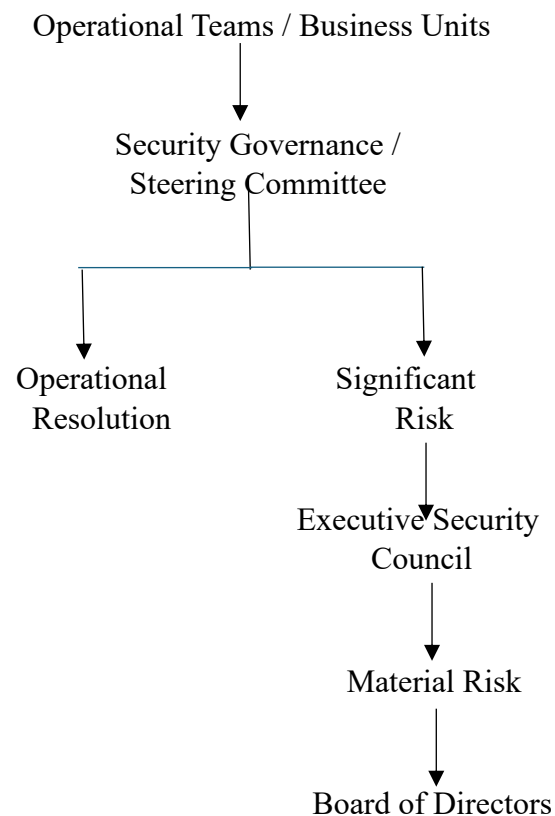
1. Review incident-response readiness.
2. Coordinate incident exercises.
3. Review lessons learned from incidents.
4. Identify recurring control weaknesses.
5. Recommend improvements.
6. Escalate significant incidents through the defined governance structure.

4. How Business Units Participate

Their role would be to:

1. Represent business-unit security concerns.
2. Communicate security requirements to their teams.
3. Report local risks.
4. Participate in governance discussions when relevant.
5. Support implementation of security policies.
6. Help coordinate awareness activities.
7. They do not create their own independent security policies.

5. Decision and Risk Information Flow



Terms of Reference for the Security Governance Ecosystem.

Area	Proposed Definition
Purpose	Provide cross-functional governance of TechGlobal's information security programme and cyber risk.
Chair	CISO
Membership	CISO, CRO/Risk, IT, Legal, Finance, HR and Business Unit representatives

Frequency	Monthly
Quorum	Chair plus representatives from Risk and at least two other core functions
Decision Scope	Security policies, risk treatment, security programme matters, third-party risks, vulnerabilities and governance actions
Escalation	Significant risks are escalated to the Executive Security Council
Board Escalation	Material risks are escalated through executive management to the Board
Records	Agenda, minutes, decisions, action items and decision log
Review	Terms of Reference reviewed annually or after a major governance change

Sample Committee Agenda

1. TechGlobal Security Governance Committee
2. Date: Monthly meeting
Chair: CISO
3. Opening and confirmation of previous minutes
4. Review of outstanding actions
5. Enterprise cyber-risk dashboard
6. New/high-risk issues
7. Security policy and standards updates
8. Vulnerability remediation status
9. Third-party security risks
10. Security awareness performance
11. Major incidents and lessons learned
12. Business Unit security issues
13. Decisions requiring Executive Security Council escalation
14. Review of decision log
15. Action owners and deadlines
16. Closing

Sample Decision Log

Date	Decision / Issue	Decision Owner	Decision Rationale	Action / Owner	Review Date
23/09/2026	Critical vulnerability requires accelerated remediation	CISO	Risk exceeds normal remediation tolerance	IT to remediate affected systems	12/10/2026
23/09/2026	Third-party vendor requires additional security assessment	CISO / Risk	Vendor handles sensitive organisational information	Risk + IT to complete assessment	19/10/2026

23/09/2026	Security awareness completion below target in one business unit	Business Unit Leader	Low completion creates increased human-risk exposure	HR + BU to complete targeted awareness campaign	02/11/2026
------------	---	----------------------	--	---	------------

12-Month Governance Calendar

Month	Key Governance Activity
October	Annual security strategy and governance planning
November	Enterprise cyber-risk assessment review
December	Security policy and standards review
January	Security budget and investment review
February	Third-party security risk review
March	Security awareness and people-risk review
April	Incident-response exercise
May	Vulnerability and remediation governance review
June	Mid-year security programme review
July	Business continuity / recovery governance review
August	Board cyber-risk reporting and assurance review
September	Annual governance effectiveness review and next-cycle planning

Task 4 — RACI Accountability Matrix

1. TechGlobal RACI Matrix

Activity	Board	CEO	CISO	CRO / Risk	Legal	Finance	HR	IT	BU Leader
Cybersecurity strategy approval	A	A	R	C	C	C	I	C	C
Security policy approval	I	A	R	C	C	I	C	C	C
Enterprise cyber-risk assessment	I	I	R	A	C	C	C	C	C
Risk acceptance	I	A	R	C	C	C	I	C	C
Security budget approval	A	R	C	C	I	R	I	C	C
Security architecture approval	I	A	A	C	I	I	I	R	C
Third-party security review	I	I	A	C	C	I	I	R	C
Access governance	I	I	A	C	C	I	R	R	C

Incident response governance	I	A	R	C	C	I	C	R	C
Material incident escalation	I	A	R	C	C	I	I	R	C
Regulatory notification decision	I	A	C	C	R	I	I	C	I
Security awareness programme	I	I	A	C	C	I	R	C	C
Vulnerability remediation oversight	I	I	A	C	I	I	I	R	C
Business continuity / recovery governance	I	A	C	C	C	C	C	R	R
Board cyber-risk reporting	A	R	R	C	C	C	I	C	I

4.4 Three Problematic Assignments

Problem 1: IT being Accountable for Security Governance

If IT were made A for overall cybersecurity strategy or security policy, this would recreate TechGlobal's existing IT-centric model.

Problem:

IT would potentially be setting security requirements, implementing them and judging their effectiveness.

Correction:

CISO should own security governance while IT remains responsible for technical implementation.

Problem 2: CISO being Accountable for Enterprise Risk Acceptance

If the CISO were the sole A for risk acceptance, there would be a potential conflict because the CISO is also responsible for security risk identification and treatment recommendations.

Problem:

The same function could identify the risk, recommend the treatment and independently accept the residual risk.

Correction:

Executive management should own significant risk acceptance, with CRO/Risk providing independent enterprise-risk oversight.

Problem 3: Legal being Accountable for the Entire Incident Response

Legal should not own the entire technical incident response process.

Problem:

Legal has the necessary regulatory expertise but does not own technical containment, eradication or recovery.

Correction:

CISO owns security incident governance, IT performs technical response activities, and Legal is responsible for legal/regulatory advice and notification matters.

How Managers Should Use the RACI Matrix

The practical rule should be:

During planning

Identify the activity and check who is A and R before work begins.

During approvals

The person marked A makes or owns the decision.

People marked C must be consulted before the decision where their expertise is relevant.

During implementation

The R role performs the work and provides evidence of completion.

During incidents

Managers should immediately identify:

- Who is A?
- Who is R?
- Who must be C?
- Who needs to be I?

After completion

The accountable owner confirms that the activity or decision has been completed and that evidence has been retained.

Task 5 Cyber-Risk Escalation and Segregation of Duties

1. Cyber-Risk Escalation Workflow

The proposed TechGlobal escalation model should move cyber-risk information from the people who **detect and manage the issue operationally** through management and executive governance, and ultimately to the Board when the risk becomes material.

Workflow:

Operational Teams / Business Units



CISO / Security Governance Team



Security Governance / Steering Committee



Executive Security Council / CEO



Board of Directors

2. Escalation Levels

Level 1 — Operational Management

Security analysts, IT teams and Business Units identify and manage routine security risks within approved policies and risk tolerance.

Examples:

- Routine vulnerabilities
- Minor security events
- Access-control issues
- Low-impact policy deviations

Issues are recorded and monitored by the responsible operational owner.

Level 2 — Executive Escalation

Issues are escalated to the Executive Security Council/CEO when they exceed operational authority, require significant resources, involve substantial business impact or require executive risk decisions.

Examples:

- Significant business disruption
- Major security incidents
- Material financial exposure
- Significant regulatory or legal implications
- Risks requiring acceptance of significant residual risk

Level 3 — Board Escalation

Material cyber risks are escalated to the Board when they could materially affect the organisation's strategic objectives, regulatory position, reputation, financial position or risk appetite.

The Board provides oversight and challenge rather than managing the technical response.

This structure addresses the scenario's existing weakness of having no reliable escalation path and limited Board visibility.

Level	Example Trigger	Decision Authority	Required Notification	Target Response
Level 1 – Operational	Low-impact vulnerability, routine security event, isolated control issue	IT / BU Owner	CISO through normal reporting	Within normal operational SLA
Level 2 – Significant	High-risk vulnerability, repeated control failure, significant third-party risk, cross-BU issue	CISO / Security Governance Committee	CRO/Risk and relevant functions	Same business day
Level 3 – Executive	Major incident, significant business disruption, substantial financial/legal exposure, significant residual risk	CEO / Executive Security Council	CISO, CRO/Risk, Legal and relevant executives	Immediate / within hours
Level 4 – Material / Board	Material impact to business, regulatory position, reputation, financial position or risk appetite	Board oversight with CEO/executive management	Board and relevant executive stakeholders	Immediate escalation

3. Segregation of Duties and Accountability Weakness Register

ID	Weakness / Conflict	Risk Created	Roles Involved	Recommended Control	Residual Risk / Review
SoD-01	IT function controls security decisions, risk approval and operations	Excessive concentration of authority and reduced independent challenge	IT / CISO / CRO	Separate security governance, enterprise risk oversight and technical implementation responsibilities	Review quarterly
SoD-02	CISO could both recommend significant risk treatment and independently approve acceptance	Significant residual risks may be accepted without sufficient independent challenge	CISO / CRO / CEO	CISO recommends treatment; CRO provides risk oversight; CEO or delegated executive approves significant acceptance	Review quarterly
SoD-03	IT may implement security controls and effectively assess its own effectiveness	Control weaknesses may not receive sufficient independent challenge	IT / CISO	IT implements controls; CISO provides security oversight and assurance; independent	Annual review

				assurance reviews effectiveness where appropriate	
SoD-04	Legal/regulatory decisions could be mixed with technical incident-response decisions	Regulatory obligations may be missed or technical/legal responsibilities confused	Legal / CISO / IT	CISO leads security response; Legal advises on regulatory obligations and notification; CEO/executive authority makes required executive decisions	Review after major incidents
SoD-05	Business Units can make local security decisions without central governance	Inconsistent controls and security standards across offices/business units	BU Leaders / CISO	Central security policies and standards with BU ownership for implementation within business processes	Quarterly